

K2: Sicherung gegen innen

Christopher Scherb <christopher.scherb@fhnw.ch>

FHNW Hochschule für Technik

2. Oktober 2025

VLANs und Netzwerkdesign

Warum Netzwerksegmentierung?

Problem: Ein großes, flaches Netzwerk

- ▶ Alle Geräte im selben Broadcast-Domain
- ▶ Kompromittiertes Gerät hat Zugriff auf alles
- ▶ Schwierige Kontrolle und Überwachung
- ▶ Kein Schutz zwischen verschiedenen Bereichen

Lösung: Segmentierung mit VLANs

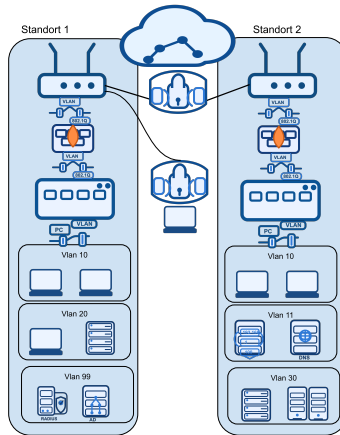
- ▶ Logische Trennung des Netzwerks
- ▶ Reduzierung der Angriffsfläche
- ▶ Kontrolle des Datenverkehrs zwischen Segmenten
- ▶ Einfachere Durchsetzung von Sicherheitsrichtlinien

Best Practice: Funktionale Segmentierung

Typische VLAN-Segmente in Unternehmen:

- ▶ **Management-VLAN:** Zugriff auf Switch/Router-Management
- ▶ **Office/Client-VLAN:** Arbeitsplatz-PCs und Laptops
- ▶ **Server-VLAN:** Interne Server (File, Print, Application)
- ▶ **DMZ-VLAN:** Öffentlich erreichbare Server (Web, Mail)
- ▶ **Gast-VLAN:** Besucher-Zugang (isoliert, Internet-only)
- ▶ **VoIP-VLAN:** IP-Telefonie (QoS-prioritiert)
- ▶ **IoT/OT-VLAN:** Drucker, Kameras, Gebäudeautomation

Referenzarchitektur: Klassisches Netzwerk



Design-Prinzipien

Grundprinzipien:

- ▶ **Least Privilege:** Nur notwendiger Zugriff
- ▶ **Defense in Depth:** Mehrere Schutzschichten
- ▶ **Zero Trust:** Vertraue niemandem, verifiziere alles

Praktische Umsetzung:

- ▶ ACLs zwischen VLANs
- ▶ Firewall-Regeln pro Segment
- ▶ Monitoring des Inter-VLAN-Verkehrs
- ▶ Regelmäßige Review der Segmentierung

Typische VLAN-IDs und Konventionen

Namenskonventionen und Nummerierung:

- ▶ **VLAN 1:** Native/Default VLAN (nicht nutzen!)
- ▶ **VLAN 10-19:** Management und Infrastruktur
- ▶ **VLAN 20-49:** Office/Client-Netze
- ▶ **VLAN 50-79:** Server und Dienste
- ▶ **VLAN 80-89:** DMZ und öffentliche Dienste
- ▶ **VLAN 90-99:** Gast und temporäre Netze
- ▶ **VLAN 100+:** Standortspezifische Segmente

Wichtig: Konsistente Dokumentation und Naming!

Motivation und Überblick

Kapitel 2: Sicherung gegen innen

Bedrohungsszenario: Kompromittiertes Gerät im Unternehmensnetz

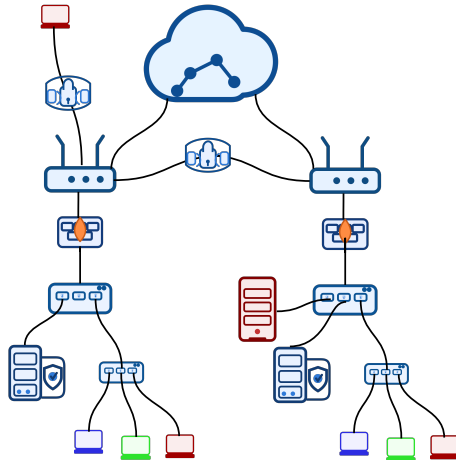
Ausgangslage:

- ▶ Laptop/PC eines Mitarbeitenden ist kompromittiert
- ▶ Malware gelangt über Phishing, Drive-by-Download oder USB ins Netz
- ▶ Angreifer hat Zugriff auf internes Netzwerk
- ▶ Perimeter-Sicherheit wird umgangen

Gefahren:

- ▶ Lateral Movement
- ▶ Datenexfiltration
- ▶ Privileg-Eskalation
- ▶ Persistenz
- ▶ Ransomware-Ausbreitung

Angriffsszenario: Interner Angreifer



Sicherheit für Endgeräte

Übersicht über Sicherheit für Endgeräte

- ▶ Viele Angriffe auf die Netzwerkinfrastruktur kommen von innen.
- ▶ Die Sicherung des internen Netzes ist ebenso wichtig wie die Sicherung gegen das öffentliche Internet.
- ▶ Infizierte interne Computer können Ausgangspunkte für Angriffe werden.
- ▶ Nachlässige Mitarbeitende sind vielleicht die größte Bedrohung.

Traditionell vs. Neu

Traditionell:

- ▶ Firmeneigene Geräte
- ▶ Vom Arbeitgeber kontrolliert
- ▶ Klare Grenzen innen/außen

Neu:

- ▶ Mobile Geräte auf Reisen
- ▶ BYOD (Bring Your Own Device)
- ▶ Herausforderung: Kontrollierter Zugang für diverse Geräte und OS
- ▶ Unternehmen müssen erwarten, erfolgreich angegriffen zu werden

Fragen nach erfolgreichem Angriff

- ▶ Woher kam der Angriff?
- ▶ Was war der Einstiegspunkt?
- ▶ Welche Systeme sind betroffen?
- ▶ Kann die Bedrohung beseitigt werden?
- ▶ Was muss aufgeräumt werden?
- ▶ Wie können weitere Angriffe bekämpft werden?

Wichtige Abwehransätze

Grundlegende Maßnahmen:

- ▶ Antivirensoftware auf Endgeräten
- ▶ EDR-Systeme (Endpoint Detection and Response)
- ▶ Spam-Filterung
- ▶ URL-Filterung
- ▶ Festplattenverschlüsselung

Wichtige Lösungen:

- ▶ AMP (Antimalware Protection)
- ▶ ESA (Email Security Appliance)
- ▶ WSA (Web Security Appliances)

Schutz gegen Malware – Kategorisierung

(1) **Statische Analyse** (Codesequenzanalyse, Mustererkennung)

- a. Host-basiert (Antivirenprodukte, z.B. McAfee, Windows Defender)
- b. Netzwerk-basiert (DPI-Firewalls mit IPS – Traffic muss entschlüsselt sein)

(2) **Dynamische Analyse** (Softwareverhalten analysieren)

- a. Sandbox-Ausführung (z.B. isolierte Umgebungen, Malware-Detonation)
- b. Systemausführung mit Verhaltensklassifikation (z.B. CrowdStrike, SentinelOne, EDR-Lösungen)

Nachteile der Ansätze

- ▶ **Statische Analyse:** Signaturen können mit Malware-Obfuskation immer verändert werden
- ▶ **Dynamische Analyse:** Verteidiger ist immer einen Schritt hinter dem Angreifer; kein Schutz gegen Zero-Day-Exploits

Threat Intelligence

Was ist Threat Intelligence?

- ▶ Wissensbasierte Informationen über bestehende oder aufkommende Bedrohungen
- ▶ Unterstützt fundierte Entscheidungen zur Reaktion auf Bedrohungen
- ▶ Basiert auf Datensammlung, Analyse und Kontextualisierung

Quellen und Typen:

- ▶ **Open Source Intelligence (OSINT):** Öffentlich verfügbare Quellen
- ▶ **Commercial Feeds:** Bezahlte Threat Intelligence-Dienste (z.B. Talos, AlienVault, CrowdStrike)
- ▶ **Community Sharing:** ISACs, CERTs, Branchen-Netzwerke
- ▶ **Internal Intelligence:** Eigene Logs, Incident-Daten, Honeypots

Threat Intelligence – Anwendungsbereiche

Strategische Ebene:

- ▶ Trends und Risikobewertung für Management-Entscheidungen
- ▶ Investitions- und Ressourcenplanung

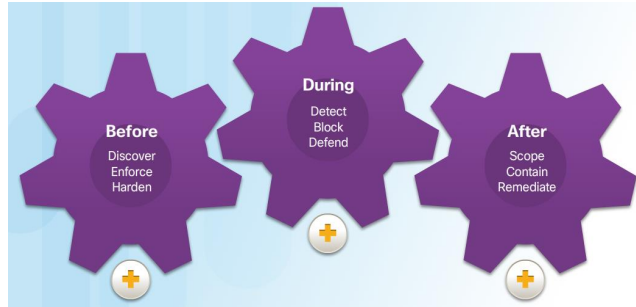
Taktische Ebene:

- ▶ TTPs (Tactics, Techniques, Procedures) von Angreifergruppen
- ▶ Anpassung von Erkennungsregeln und Verteidigungsstrategien

Operative Ebene:

- ▶ IoCs (Indicators of Compromise): IP-Adressen, Domains, Hashes
- ▶ Automatische Integration in Firewalls, IDS/IPS, SIEM
- ▶ Schnelle Reaktion auf aktuelle Kampagnen

Verteidigung umfasst drei Phasen



- ▶ **Before:** Discover, Enforce, Harden
- ▶ **During:** Detect, Block, Defend
- ▶ **After:** Scope, Contain, Remediate

Policy Enforcement mit Whitelisting distinkter Applikationen

- ▶ Regeln durchsetzen, was Applikationen dürfen oder nicht dürfen
- ▶ Rechte für einzelne Applikationen für potentiell gefährliche Aktionen vergeben
- ▶ Ziel: Nicht Malware-Erkennung (statisch), sondern Verhaltensregel-Durchsetzung (dynamisch)

Sicherheit für E-Mail und Web

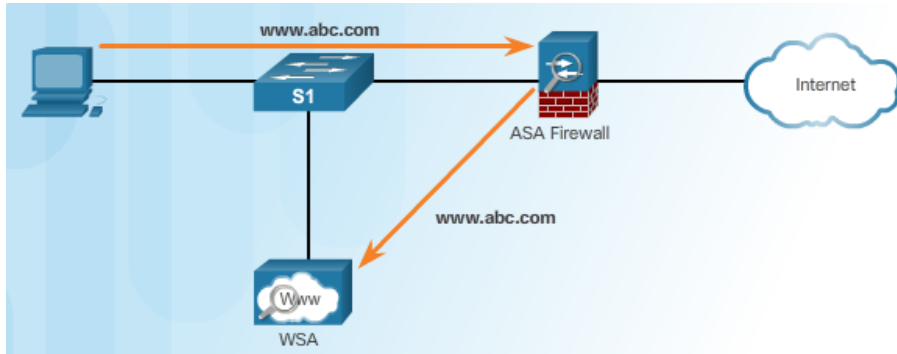
Haupteinfalltore für Malware:

- ▶ E-Mail-Verkehr
- ▶ Web-Verkehr

Gatekeeper:

- ▶ **ESA:** Email Security Appliance (früher IronPort)
- ▶ **WSA:** Web Security Appliance (inkl. AMP und Application Visibility & Control)
- ▶ **CWS:** Cloud Web Security (z.B. Talos)

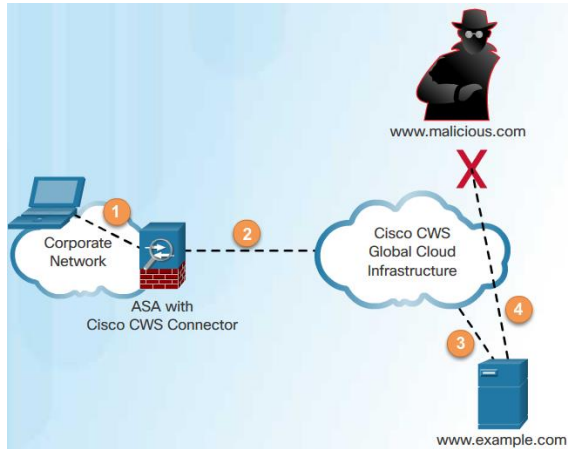
WSA Sequenz



Web Security

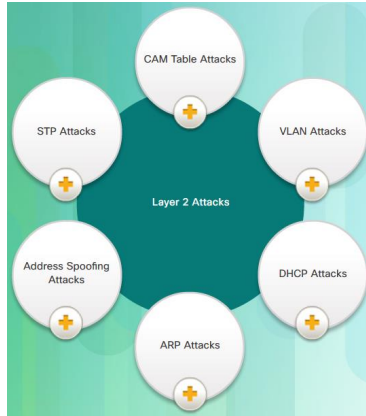
- ▶ Web Security kann in moderne DPI-Firewalls (Next-Gen Firewalls) integriert werden
- ▶ Erfordert URL-Filtering und Threat-Intelligence-Integration
- ▶ Firewall muss als Web-Proxy fungieren und SSL/TLS entschlüsseln
- ▶ CA-Zertifikat der Firewall muss auf Clients verteilt werden (SSL Inspection)

CWS Cloud Web Service

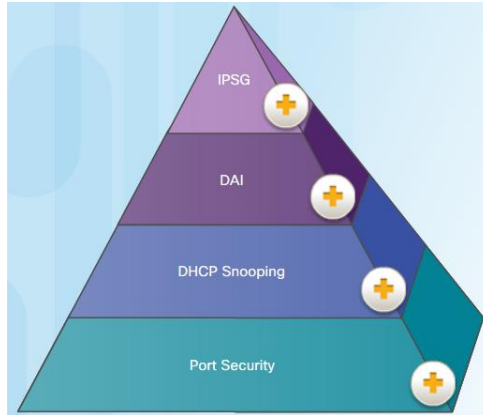


Schicht-2-Sicherheitsmaßnahmen

Verletzlichkeiten der Schicht 2



Verteidigung – Überblick



Angriff auf die MAC-Tabelle

Verletzlichkeit:

- ▶ Wenn Zieladresse nicht in MAC-Tabelle gefunden wird, wird Frame an alle Ports geflutet (außer Eingangsport)

Angriffsmechanismus:

- ▶ Angreifer flutet Switch mit gefälschten MAC-Adressen
- ▶ MAC-Tabelle läuft voll, legitime Client-Adressen können nicht gespeichert werden
- ▶ Frames für solche Clients werden an alle Ports geflutet, inklusive Angreifer (der mithören kann)

Verteidigung: Port Security **Angriffstool:** macof (auf Linux-Hosts)

Port Security – Konfigurationsanforderungen

- ▶ Port muss im Access-Modus sein
- ▶ Port Security aktivieren
- ▶ Anzahl MAC-Adressen pro Port begrenzen
- ▶ Optional: MAC-Adressen speichern
- ▶ Optional: Verletzungsaktion definieren (protect, restrict, shutdown)
- ▶ Optional: MAC-Adressen-Aging-Verhalten

Port Security – Aging-Syntax

```
Switch(config-if)
```

```
switchport port-security aging {static | time time| type {absolute | inactivity}}
```

Parameter	Description
static	• Enable aging for statically configured secure addresses on this port.
time time	• Specify the aging time for this port. • The range is 0 to 1440 minutes. • If the time is 0, aging is disabled for this port.
type absolute	• Set the absolute aging time. All the secure addresses on this port age out exactly after the time (in minutes) specified and are removed from the secure address list.
type inactivity	• Set the inactivity aging type. The secure addresses on this port age out only if there is no data traffic from the secure source address for the specified time period.

Parameter:

- ▶ static: Aging für statisch konfigurierte sichere Adressen aktivieren
- ▶ time: Aging-Zeit 0–1440 Minuten
- ▶ type absolute: Alle Adressen altern nach angegebener Zeit
- ▶ type inactivity: Adressen altern nur, wenn für angegebene Zeit kein Verkehr

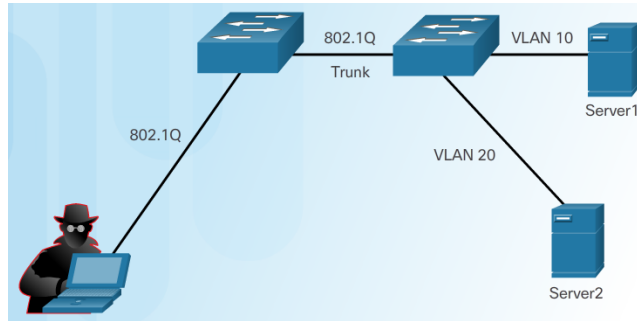
Port Security – Beispiel-Konfiguration

```
AS(config)#interface range fa0/9 - 24
AS(config-if)#switchport mode access
AS(config-if)#switchport port-security
AS(config-if)#switchport port-security maximum 10
AS(config-if)#switchport port-security violation restrict
AS(config-if)#switchport port-security mac-address sticky
! Optional:
AS(config-if)#switchport port-security aging time 10
AS(config-if)#switchport port-security aging type inactivity
```


NAC mit 802.1X

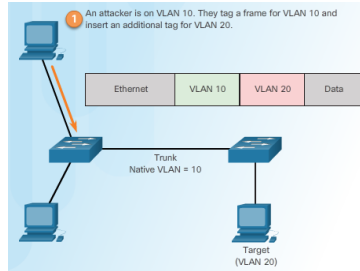
- ▶ Beste Variante: Network Access Control mit 802.1X
- ▶ Jeder Teilnehmer muss sich gegen RADIUS-Server authentifizieren
- ▶ Nur diese spezifische MAC-Adresse ist erlaubt
- ▶ Benötigt AAA und zentralen Server
- ▶ NAC schließt klassische Port Security aus

VLAN Hopping Angriff



- ▶ **Angriffspunkt:** Switch-Port im Standard-‘dynamic’-Modus belassen
- ▶ **Mechanismus:** Angreifer setzt Interface auf IEEE 802.1Q Trunk Mode, DTP schaltet Link auf Trunk Mode
- ▶ **Resultat:** Angreifer hat Zugang zu allen VLANs ohne über Router/ACL zu gehen

VLAN Double Tagging Angriff



- ▶ Funktioniert unidirektional, wenn Angreifer im selben VLAN wie Native VLAN auf Trunk-Ports
- ▶ Angreifer fügt VLAN-Tag 20 ein (trotz Access-Port)
- ▶ Switch fügt bei Ingress VLAN-Tag 10 hinzu
- ▶ Bei Switch-Egress wird VLAN-Tag 10 entfernt (Native VLAN)
- ▶ Zweiter Switch liest VLAN-Tag 20 und leitet entsprechend weiter

Verteidigung gegen VLAN-Angriffe

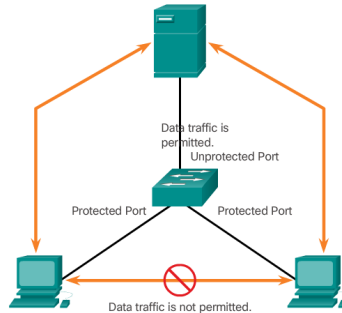
Richtlinien:

- ▶ Endgeräte dürfen nicht auf VLAN-Trunking zugreifen
- ▶ Automatisches Trunking auf Access-Ports deaktivieren, auf Access-Modus setzen
- ▶ **Trunk Ports:** Auto-Trunking deaktivieren, Trunks manuell konfigurieren
- ▶ Native VLAN auf Trunks darf nur dort existieren, nicht auf Access-Ports

VLAN-Schutz – Beispiel-Konfiguration

```
S1(config)#interface range fa0/1 - 16      ! access ports
S1(config-if-range)#switchport mode access
S1(config-if-range)#exit
S1(config)#interface range fa0/17 - 20     ! unused ports
S1(config-if-range)#switchport mode access
S1(config-if-range)#switchport access vlan 1000
S1(config-if-range)#exit
S1(config)#interface range fa0/21 - 24     ! trunk ports
S1(config-if-range)#switchport mode trunk
S1(config-if-range)#switchport trunk native vlan 99
```

PVLAN Edge Feature

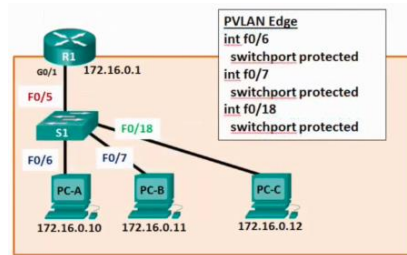


- ▶ Verhindert Layer-2-Verkehr innerhalb VLAN (Service-Provider-Situation)
- ▶ Keine Unicast-, Broadcast- oder Multicast-Frames zwischen PVLAN-Edge-Ports
- ▶ Protected Port leitet Frames nicht an anderen Protected Port auf demselben Switch weiter
- ▶ Verkehr muss über Layer-3-Gerät gehen

PVLAN Edge – Konfiguration und Beispiel

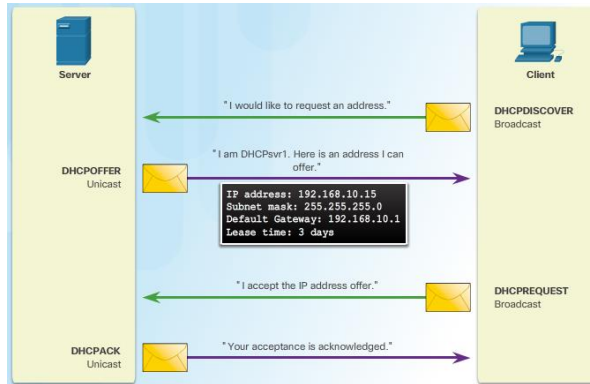
Konfiguration:

```
S1(config)#interface range fa0/1 - 16  
S1(config-if)#switchport protected
```

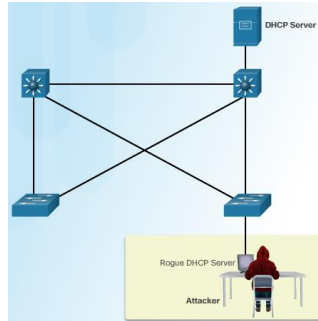


- ▶ PC-A, PC-B, PC-C können keine Frames untereinander austauschen
- ▶ Sie können zu anderen Netzen via Default Gateway kommunizieren

Korrekter DHCP-Prozess



DHCP-Angriffe

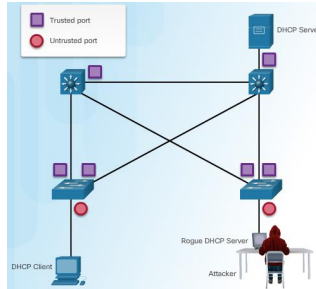


Verletzlichkeiten:

1. Fremder Computer kann auf DHCP-Anfragen antworten
2. Host kann viele DHCP-Anfragen senden und IP-Adressen erschöpfen

Verteidigung: DHCP Snooping

DHCP Snooping



- ▶ Unterscheidung 'trusted' Ports (legitime DHCP-Antworten) und 'untrusted'
- ▶ Switch hört DHCP-Verkehr auf trusted Ports, baut DHCP Snooping Database auf
- ▶ Trust muss manuell konfiguriert werden
- ▶ Nur Antworten von trusted Ports erlaubt
- ▶ Switch speichert für jede Zuteilung: MAC-Adresse, IP-Adresse, Lease-Zeit, VLAN#, Switch-Port

DHCP Snooping – Konfigurationsschritte

1. DHCP Snooping global aktivieren, DHCP Option 82 (Relay Agent Option) deaktivieren
2. Trusted Ports festlegen
3. DHCP Snooping pro VLAN aktivieren
4. Anzahl Anfragen auf untrusted Ports begrenzen

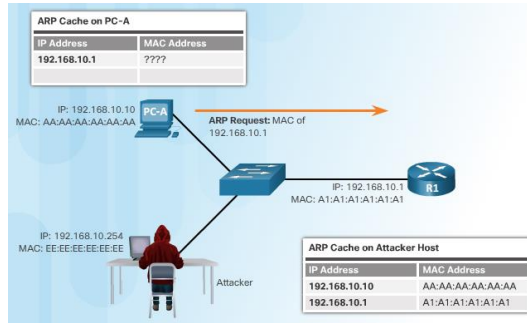
DHCP Snooping – Beispiel-Konfiguration

```
S1(config)#ip dhcp snooping
S1(config)#no ip dhcp snooping information option
S1(config)#interface f0/1
S1(config-if)#ip dhcp snooping trust
S1(config-if)#exit
S1(config)#interface range f0/9 - 24
S1(config-if)#ip dhcp snooping limit rate 10
S1(config-if)#exit
S1(config)#ip dhcp snooping vlan 10,20
```

Status-Abfrage:

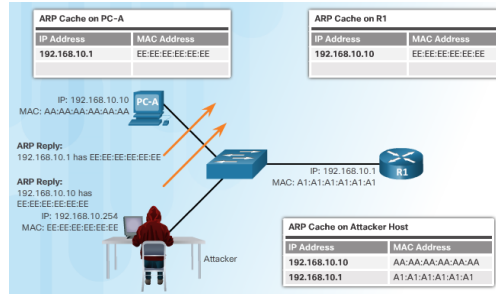
```
S1#show ip dhcp snooping [binding]
```

ARP-Angriff – Verletzlichkeit



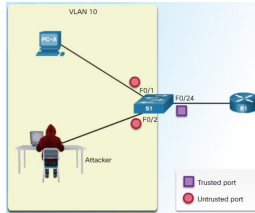
- ▶ **Verletzlichkeit:** ARP RFC erlaubt spontane ARP-Antworten (“gratuitous ARP”)
- ▶ Andere Computer speichern MAC/IP-Adresse-Paar in ihrer ARP-Tabelle
- ▶ **Angriffsmechanismus:** Angreifer sendet gratuitous ARP-Frames mit gefälschten MAC-Adressen
- ▶ **Verteidigung:** Dynamic ARP Inspection (DAI)

ARP Man-in-the-Middle Angriff



- ▶ Angreifer sendet zwei gratuitous ARP-Antworten mit eigener MAC-Adresse und fremden IP-Adressen
 - ▶ PC-A und Default Gateway aktualisieren ARP-Cache mit MAC-Adresse des Angreifers
 - ▶ Angreifer wird zum Man-in-the-Middle
- Tools:** Cain & Abel, dsniff, ettercap, Yersinia

Dynamic ARP Inspection (DAI)



- ▶ DAI baut auf DHCP Snooping auf
- ▶ Validiert ARP-Antworten/Gratuitous ARP gegen [IP, MAC, VLAN, Port]-Tabelle aus DHCP Snooping
- ▶ DAI benötigt DHCP Snooping
- ▶ Switch überwacht ARP-Requests/-Responses
- ▶ Erweitert DHCP DB mit Infos über Hosts mit statischen IP-Adressen
- ▶ Unterscheidung 'trusted' und 'untrusted' Ports (Standard)
- ▶ ARP-Antworten/Gratuitous ARP, die DB widersprechen, werden verworfen

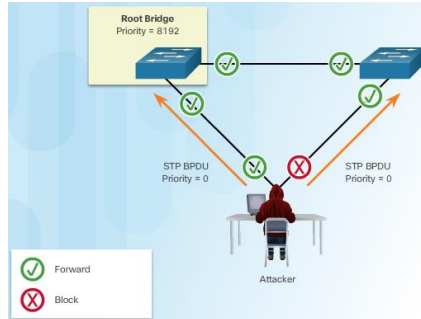
DAI – Beispiel-Konfiguration

```
S1(config)#ip dhcp snooping
S1(config)#ip dhcp snooping vlan 10
S1(config)#ip arp inspection vlan 10
S1(config)#interface f0/24
S1(config-if)#ip dhcp snooping trust
S1(config-if)#ip arp inspection trust
S1(config-if)#exit
```


Bekämpfung von Adressfälschungen

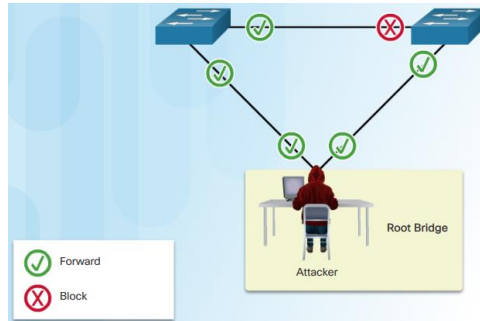
- ▶ Angreifer kann MAC-Adresse ändern, um anderen Host an Switch-Port zu imitieren
- ▶ Angreifer kann IP-Adresse ändern, um anderen Host zu imitieren
- ▶ Cisco bietet IP Source Guard Feature zur Validierung von Adressen
- ▶ In der Praxis ist die Aufrechterhaltung der Konsistenz über die Zeit schwierig
- ▶ Wird in diesem Kurs nicht verwendet

STP-Angriff – Verletzlichkeit und Mechanismus



- ▶ BPDUs können gefälscht werden
- ▶ Angreifer generiert BPDUs mit niedriger Bridge-ID auf Computer
- ▶ Computer des Angreifers erscheint als Root Bridge
- ▶ Angreifer kann Man-in-the-Middle spielen

STP-Angriff – Resultat



- ▶ Angreifer wird zur Root Bridge
- ▶ Forwarding-/Blocking-Ports werden neu angeordnet
- ▶ Gesamter Verkehr fließt über Angreifer

Verteidigung gegen STP-Angriffe

PortFast:

- ▶ Auf Access-Ports konfigurieren
- ▶ Port geht sofort in Forwarding State über ohne STP zu durchlaufen
- ▶ Port hört weiterhin auf eingehende BPDUs

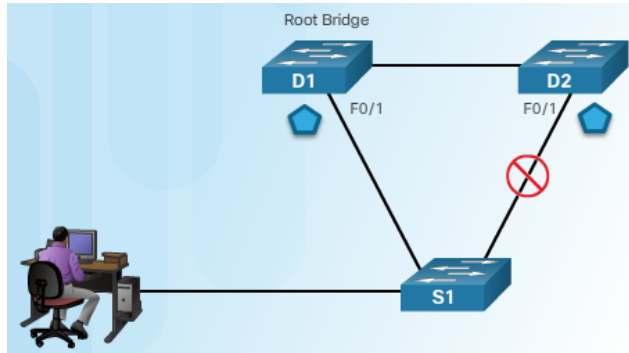
BPDU Guard:

- ▶ Sollte auf Access-Ports aktiviert werden, wo PortFast aktiviert ist
- ▶ Wenn BPDUs empfangen werden, wird Port heruntergefahren

Root Guard:

- ▶ Stellt sicher, dass Switch, der nicht Root werden soll, nicht Root werden kann
- ▶ Begrenzt Switch-Ports, wo Root ausgehandelt werden kann
- ▶ Sollte auf allen Ports aktiviert werden, die nicht Root Port werden sollen

Root Guard – Beispiel



- Root Guard sollte z.B. auf Fa0/1 von D1 und D2 aktiviert werden

STP-Schutz – Konfiguration

PortFast und BPDU Guard:

```
S1(config)#interface range fa0/9 - 24
S1(config-if)#switchport mode access
S1(config-if)#exit
S1(config)#spanning-tree portfast default
S1(config)#spanning-tree portfast bpduguard default
! Oder BPDU Guard auf Interfaces aktivieren
S1(config)#interface Fa0/9
S1(config-if)#spanning-tree portfast
S1(config-if)#spanning-tree bpduguard enable
```

Root Guard:

```
D1(config)#interface fa0/1
D1(config-if)#spanning-tree guard root
```

Zusammenfassung

- ▶ Bedrohungen von innen sind ebenso gefährlich wie von außen
- ▶ Endgerätesicherheit umfasst Malware-Schutz, E-Mail- und Web-Sicherheit
- ▶ Layer-2-Sicherheit bildet die Grundlage für ein resilientes Netzwerk
- ▶ Port Security, DHCP Snooping, DAI und STP-Schutz sind essenzielle Maßnahmen
- ▶ Kombination technischer Kontrollen und klarer Prozesse entscheidend
- ▶ Kontinuierliche Verbesserung durch Monitoring, Audits und Training